

W8D1

DVWA e Burp Suite

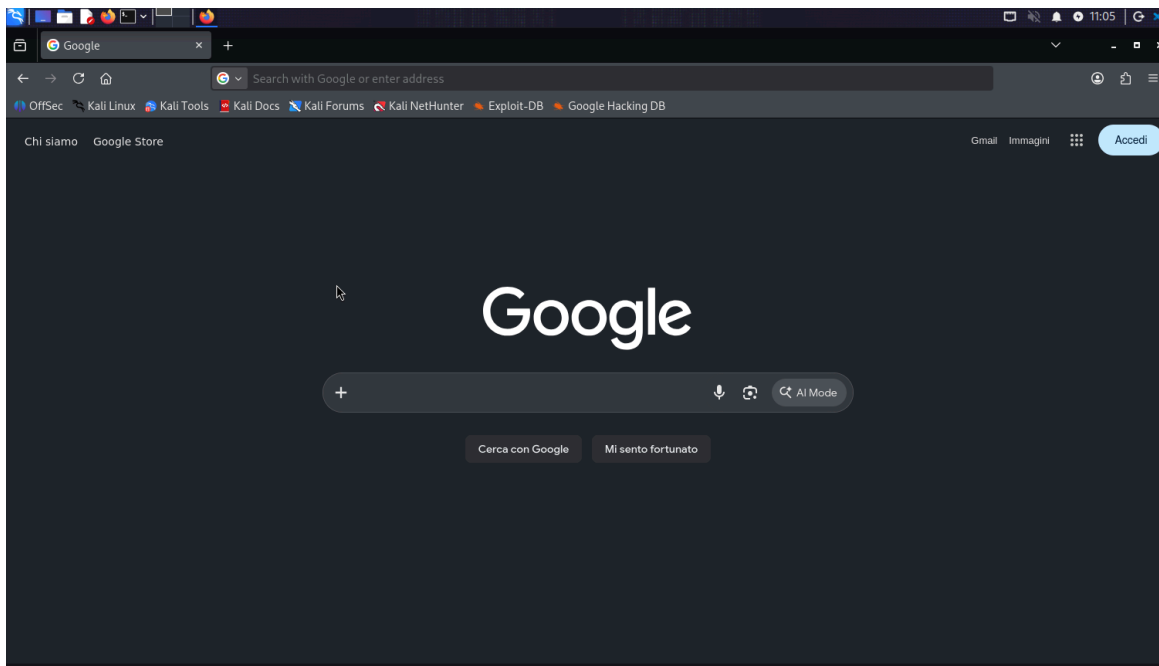
Sommario

L'esercizio si articola in due fasi. Nella prima è stata installata e configurata la Damn Vulnerable Web Application (DVWA) su Kali Linux, nella seconda fase è stato condotto un test con Burp Suite sulla pagina di login dell'applicazione: la richiesta di autenticazione è stata intercettata e la risposta è stata analizzata tramite il Repeater.

Il risultato dell'analisi è stato registrare come un tentativo di login con credenziali errate produce un redirect HTTP 302 verso la pagina login.php, alla quale è associato il messaggio «Login failed» visibile seguendo il redirect. Nella parte finale, è stata svolta e documentata con Burp l'analisi dell'effetto dei diversi livelli di sicurezza (low, medium, high) di DVWA, sia sul login sia sul modulo Brute Force.

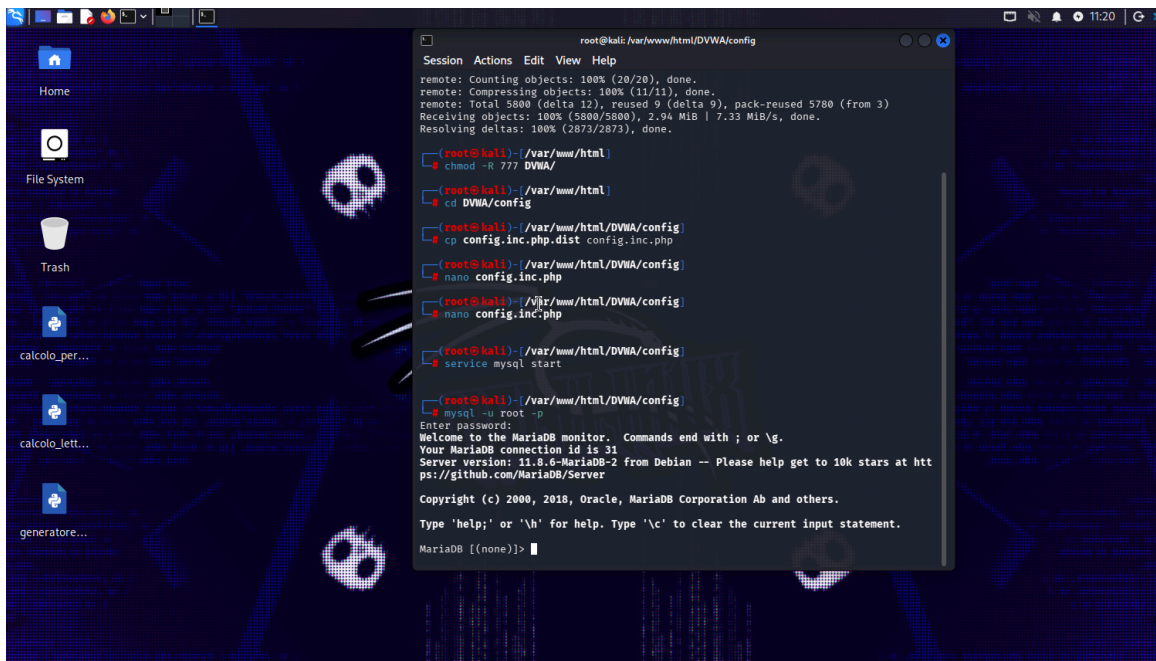
1. Installazione e configurazione di DVWA

1.1 Come prima cosa è stato verificato che Kali avesse accesso a Internet aprendo una pagina web dal browser.

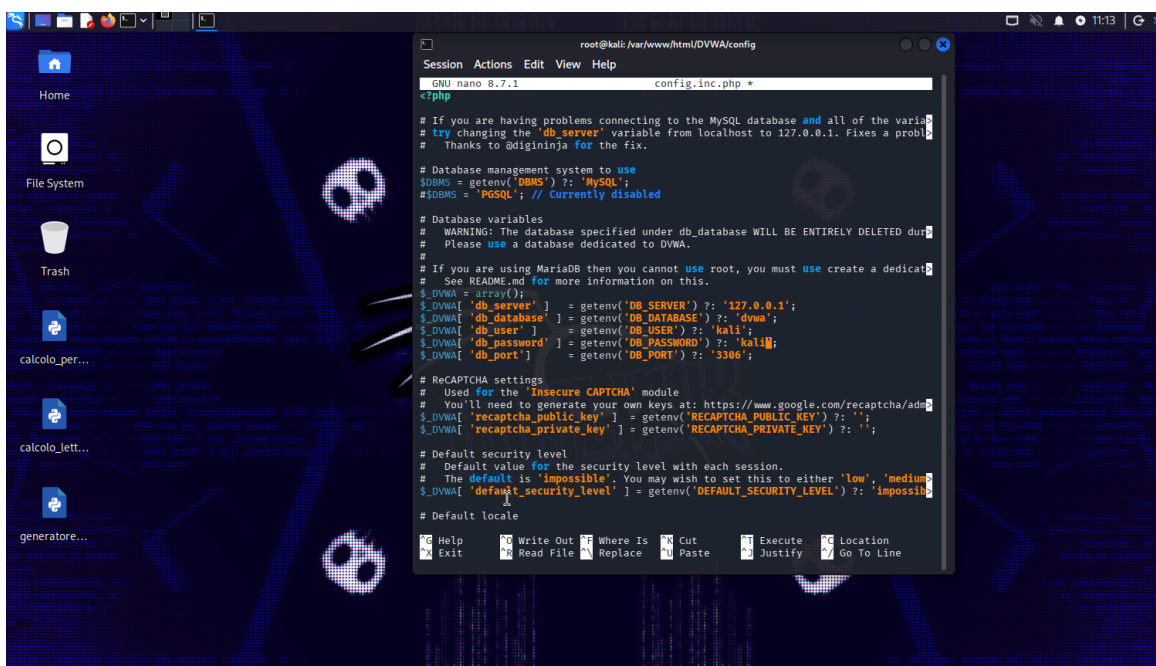


1.2 Da un terminale con utenza di root è stata clonata la repository ufficiale, sono stati assegnati i permessi alla cartella e copiato il file di configurazione:

```
cd /var/www/html  
  
git clone https://github.com/digininja/DVWA  
  
chmod -R 777 DVWA/  
  
cd DVWA/config  
  
cp config.inc.php.dist config.inc.php  
  
nano config.inc.php
```



1.3 All'interno di *config.inc.php* sono state impostate le credenziali del database utilizzate da DVWA.



1.4 È stato avviato il servizio MySQL e ci si è connessi al database con l'utenza di root. È stata poi creata l'utenza dedicata a cui sono stati assegnati i privilegi sul database dvwa.

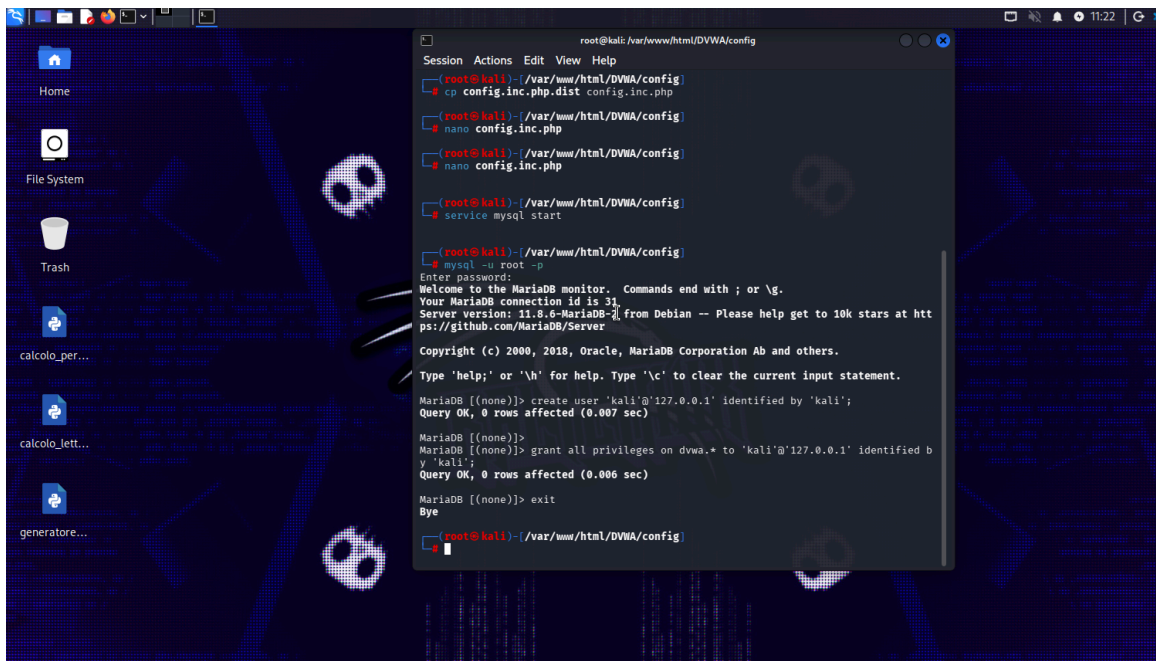
```
service mysql start

mysql -u root -p

create user 'kali'@'127.0.0.1' identified by 'kali';

grant all privileges on dvwa.* to 'kali'@'127.0.0.1' identified by 'kali';

exit
```



1.5 È stato avviato il web server e individuata la versione di PHP installata (in questo caso la 8.4) spostandosi in */etc/php* ed elencandone le sottocartelle. Nel file *php.ini* della cartella apache2 sono state impostate su **On** le direttive *allow_url_fopen* e *allow_url_include* ed è stato riavviato Apache.

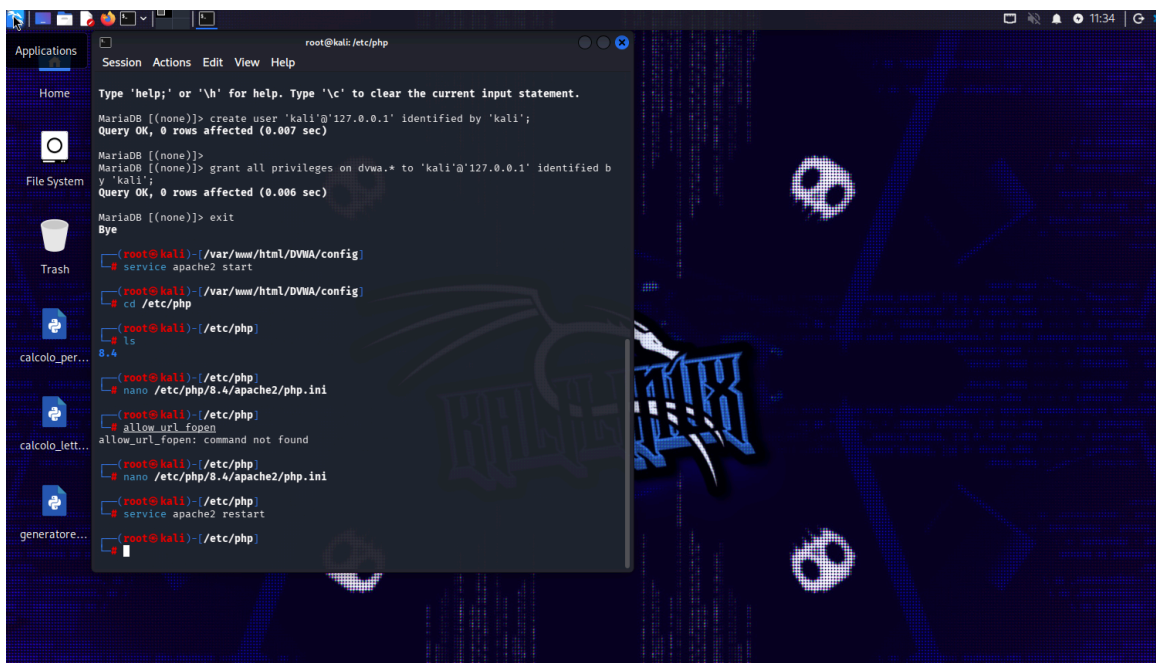
```
service apache2 start

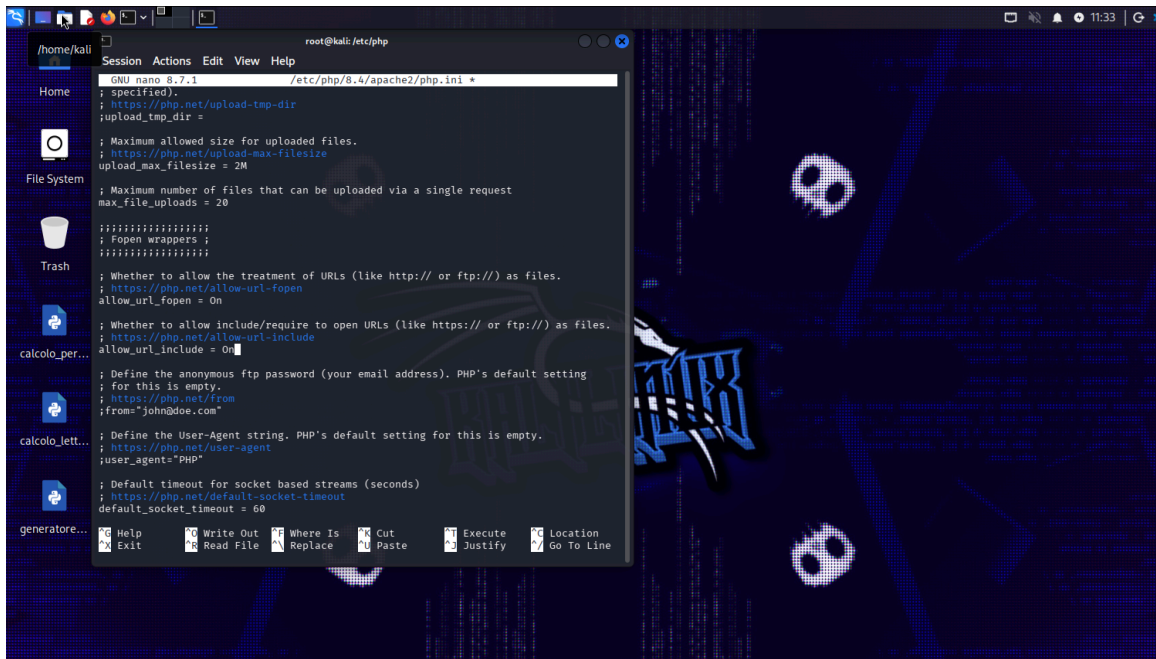
cd /etc/php

ls      # -> 8.4

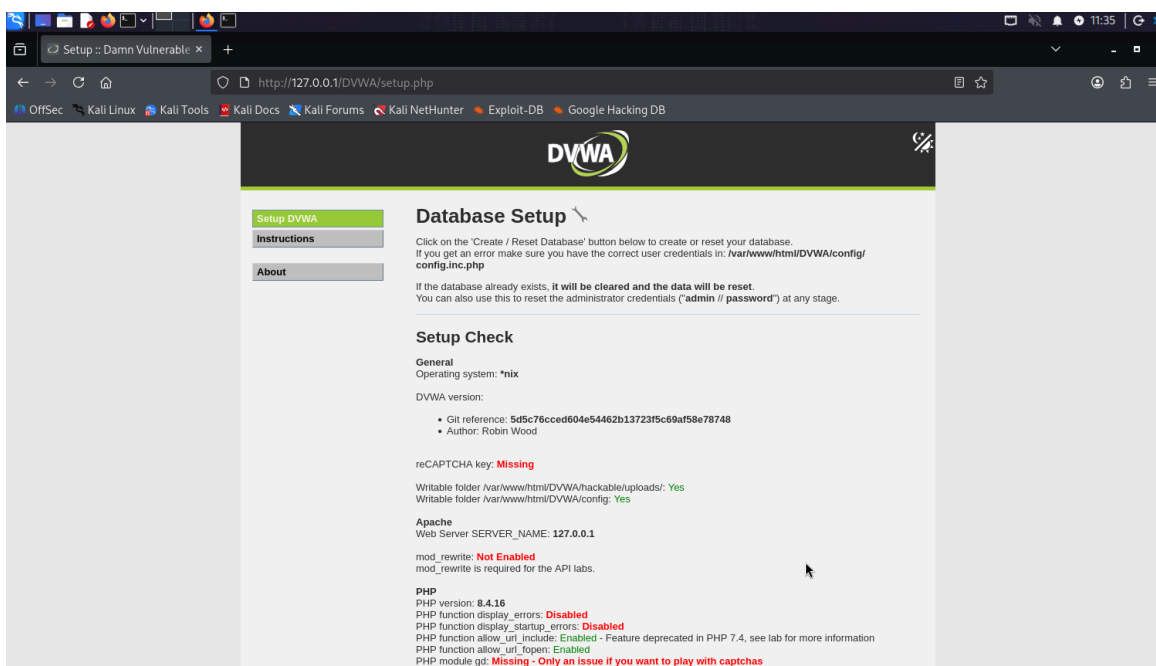
nano /etc/php/8.4/apache2/php.ini

service apache2 restart
```





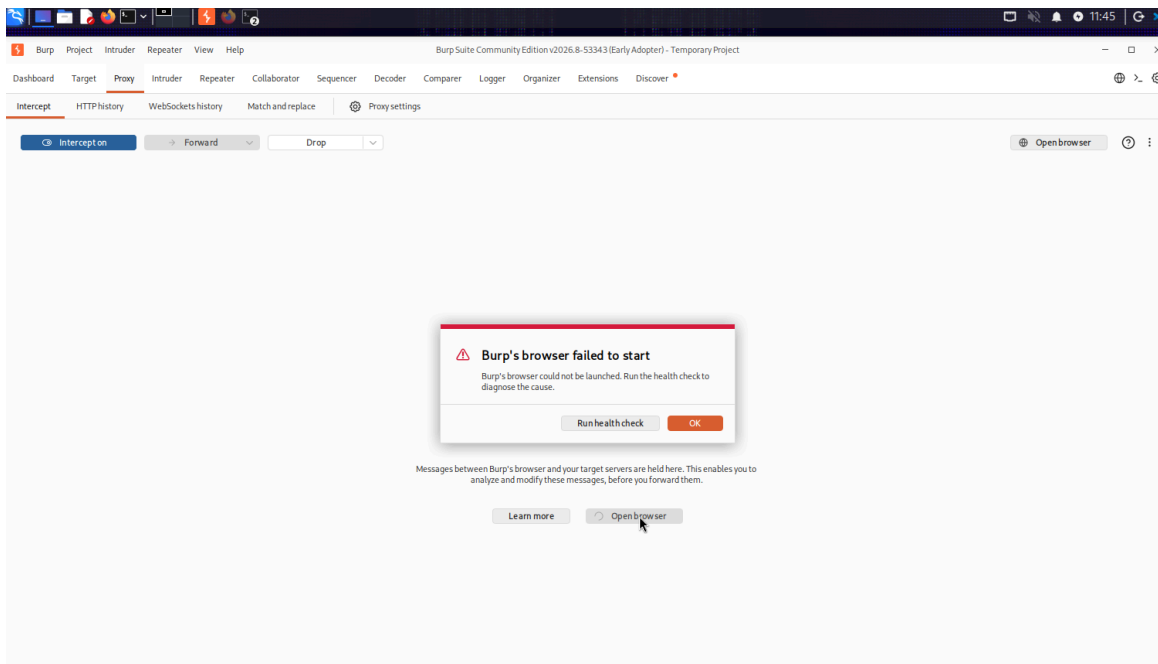
1.6 Dal browser è stato aperto l'indirizzo `127.0.0.1/DVWA/setup.php` e cliccato **Create / Reset Database** per inizializzare il database dell'applicazione.



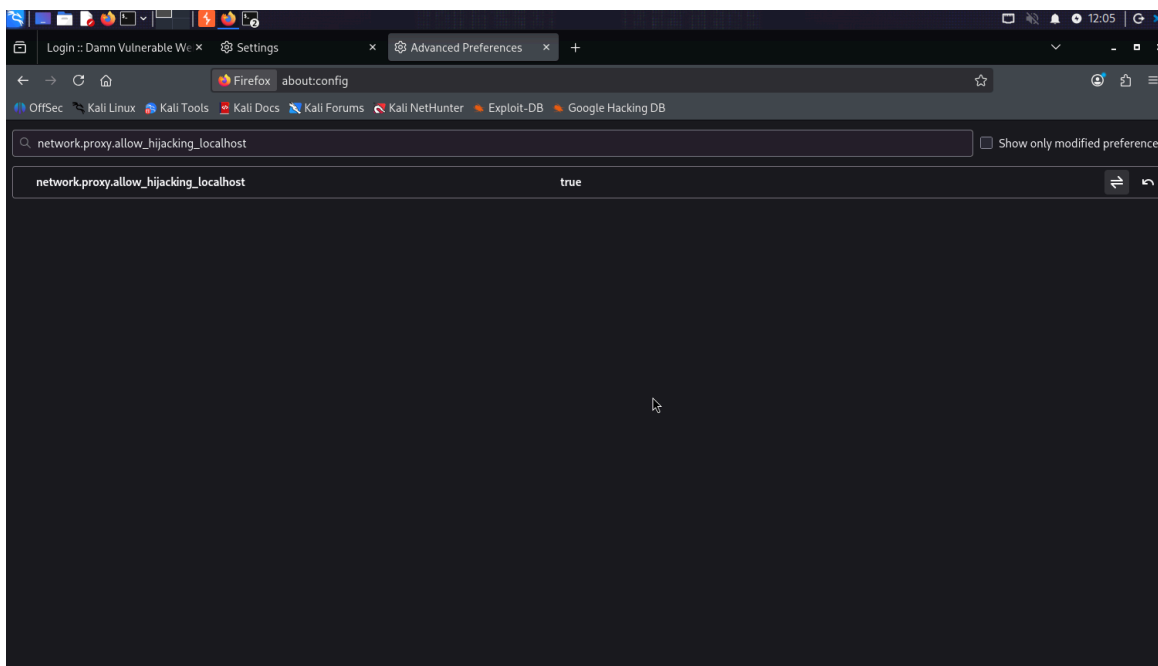
1.7 Dopo l'accesso, dalla scheda **DVWA Security** è stato impostato il livello di sicurezza su **low**.

2. Burp Suite

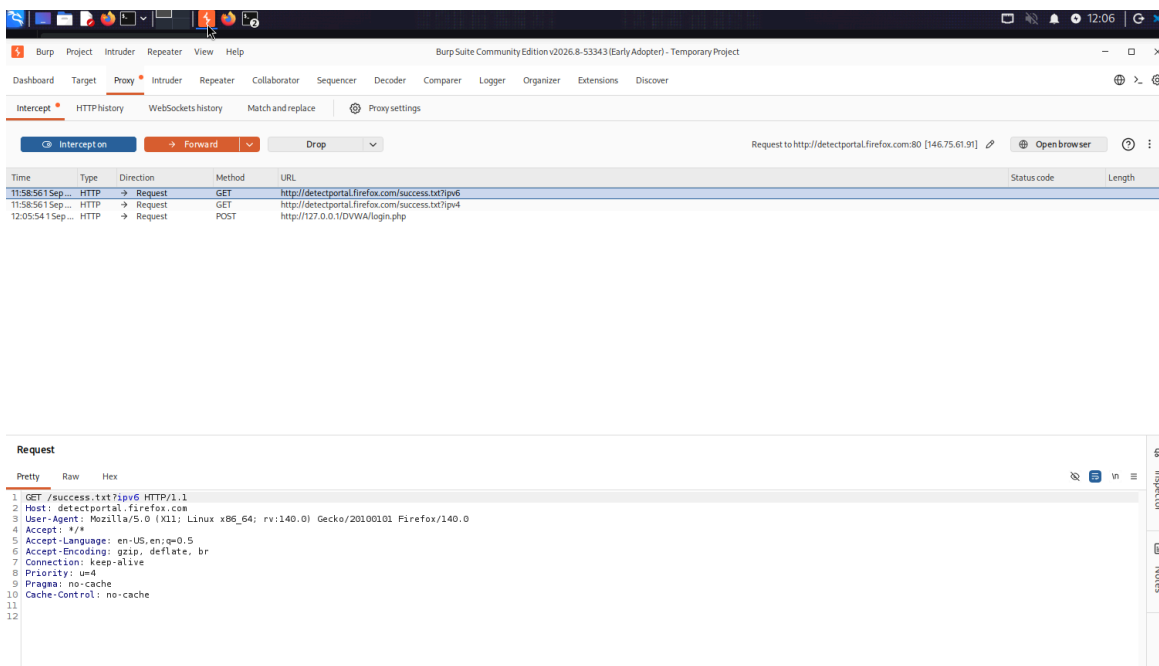
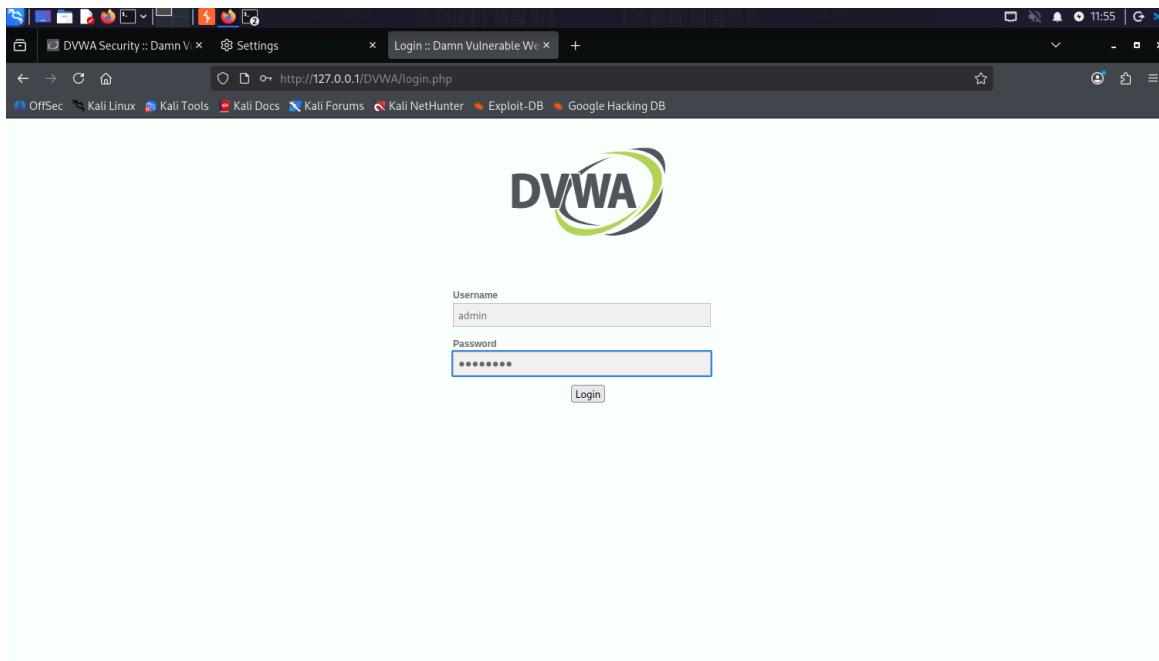
2.1 L'ambiente Kali era in esecuzione in una macchina virtuale **UTM**. In questa configurazione il browser integrato di Burp non si avviava, quindi non era utilizzabile per generare traffico da intercettare.



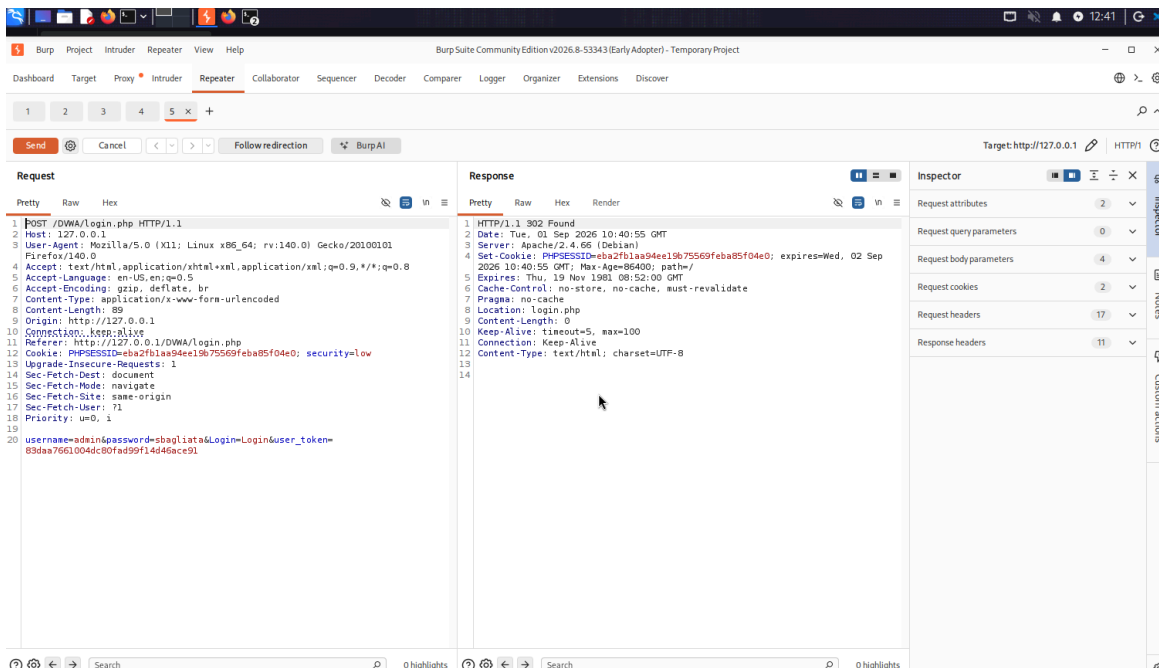
Come soluzione è stato usato **Firefox** come browser, indirizzandone il traffico al proxy di Burp (127.0.0.1:8080). Poiché DVWA è raggiungibile su localhost, Firefox per impostazione predefinita non inoltra al proxy le richieste verso 127.0.0.1, lasciando l'intercept vuoto. Per risolvere si è impostata a **true** la voce *network.proxy.allow_hijacking_localhost* in *about:config*, così da forzare l'inoltro anche del traffico verso localhost.



2.2 è stata aperta la pagina di login all'indirizzo *127.0.0.1/DVWA/login.php*, sono state inserite le credenziali predefinite **admin / password** ed è stata catturata la richiesta con Intercept di Burp attivo.

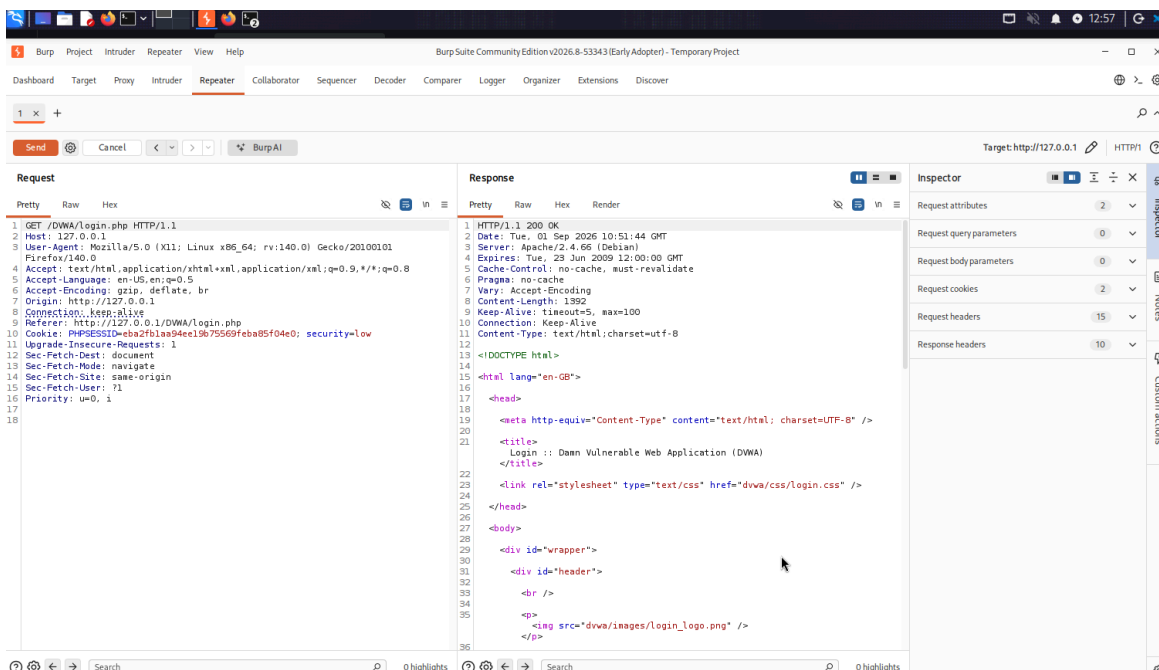


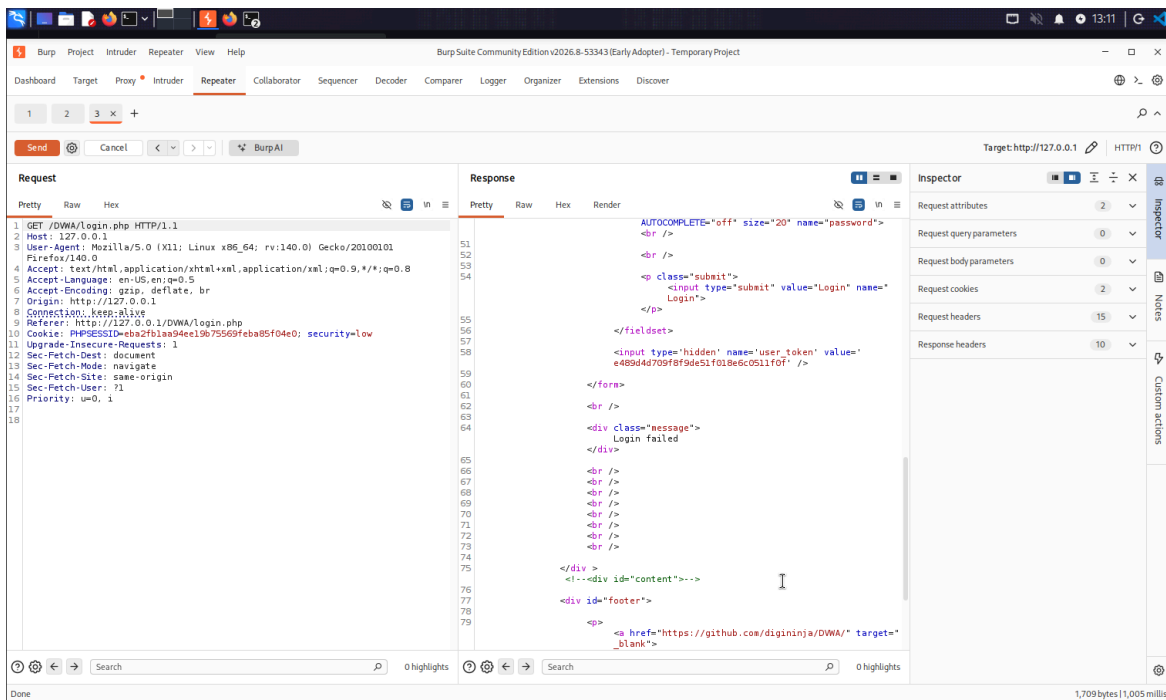
2.3 La richiesta è stata inviata al Repeater (Send to Repeater) e i campi *username* e *password* sono stati modificati con valori errati prima dell'invio. Premendo **Send** la risposta è un **HTTP 302 Found** con *Location: login.php*: il server rimanda cioè alla pagina di login.



Il redirect verso *login.php* è l'indicatore del login fallito: con credenziali corrette il redirect punterebbe invece a *index.php*.

2.4 Cliccando su **Follow redirection**, Burp segue il 302 ed esegue una GET verso `login.php`, che restituisce un **HTTP 200 OK** con la pagina di login completa. Nel corpo della risposta è ora presente il messaggio «**Login failed**», visibile nella scheda **Render**.

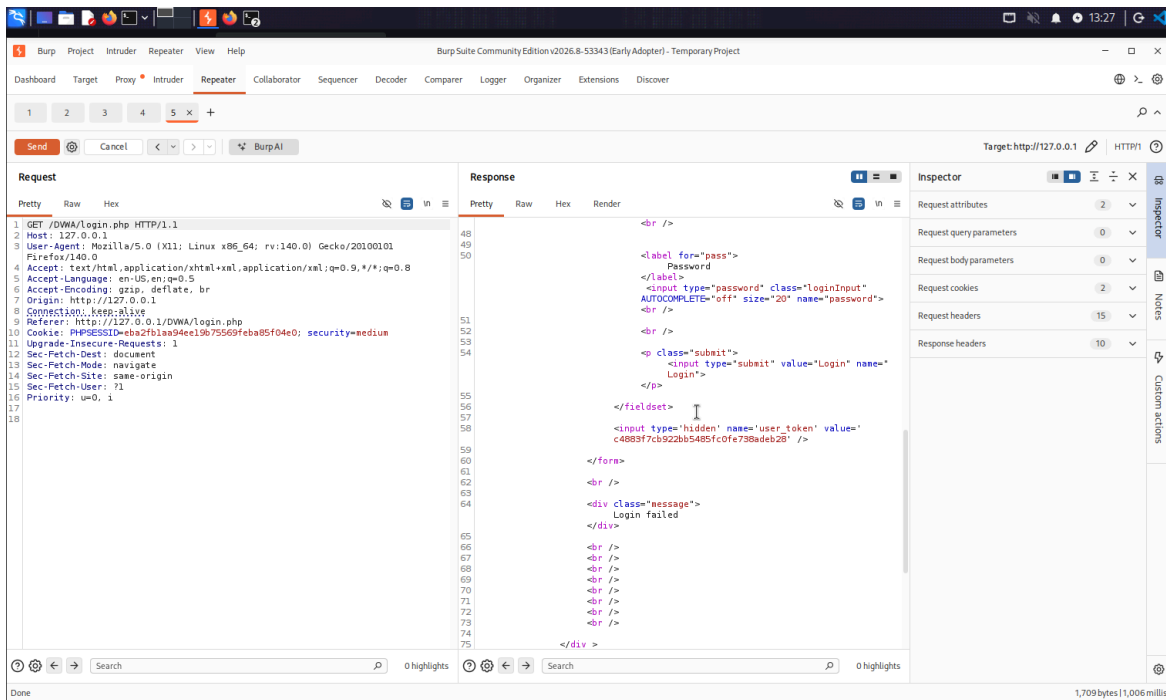




3. Differenza tra livelli di sicurezza Low, Medium e High.

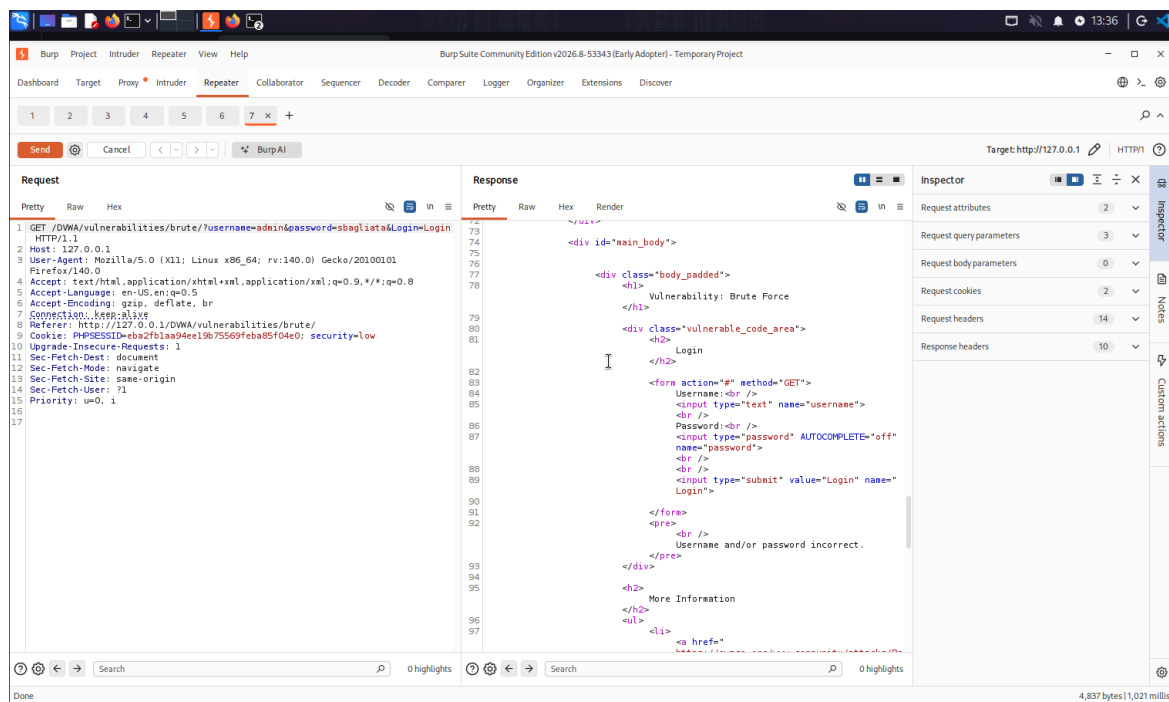
L'esercizio chiedeva di ripetere i passaggi ai livelli **Medium** e **High** e di osservare cosa cambia. L'analisi è stata condotta su due piani distinti: la pagina di login dell'applicazione e i moduli vulnerabili.

3.1 Ripetendo il login fallito su *login.php* ai livelli medium e high, il comportamento è rimasto identico a quello osservato a low: redirect e messaggio «Login failed». L'unica differenza è stato il valore del parametro *security* nel cookie della richiesta. Questo dimostra che il livello di sicurezza di DVWA non incide sul front-end, ma sui moduli vulnerabili.

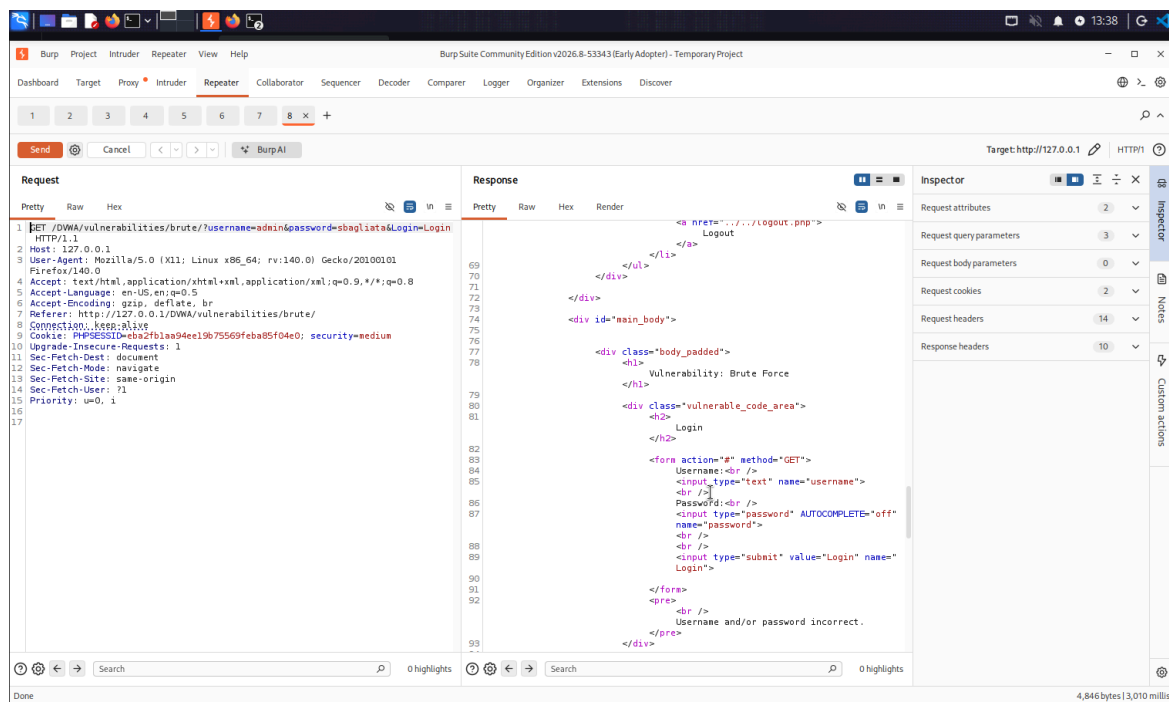


3.2 è stato usato allora il modulo Brute Force con Burp. A ciascun livello è stato inviato dal Repeater lo stesso tentativo con credenziali errate, osservando due indicatori: il tempo di risposta (in basso a destra nel Repeater) e la presenza del token anti-CSRF nella richiesta.

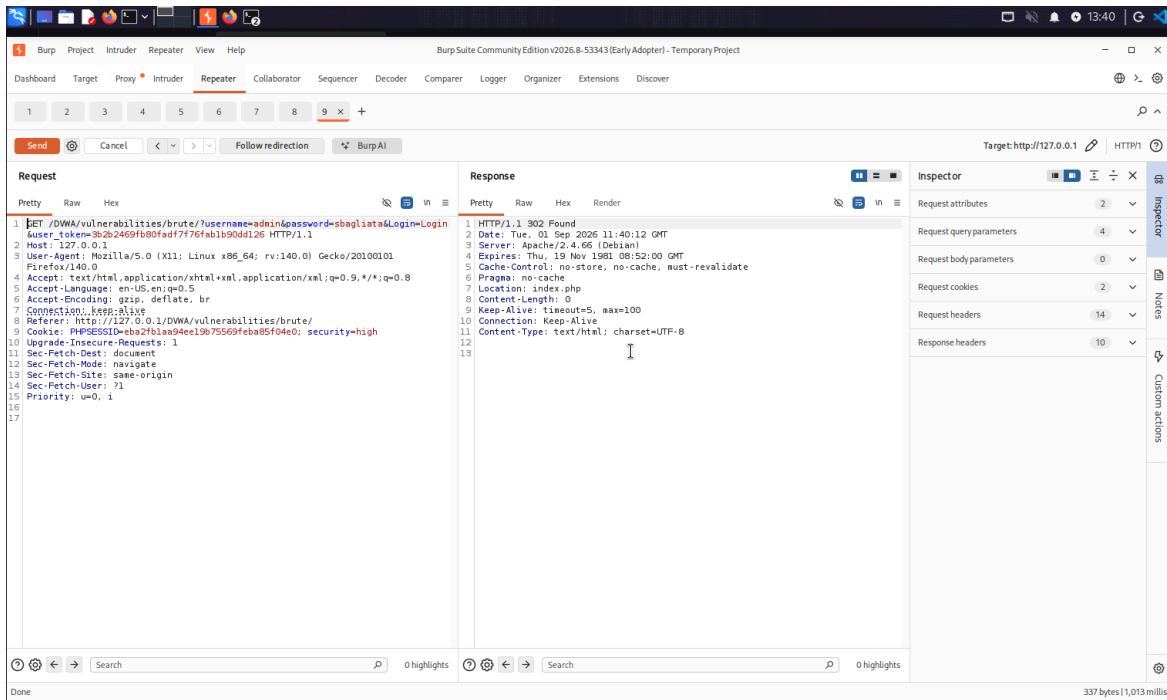
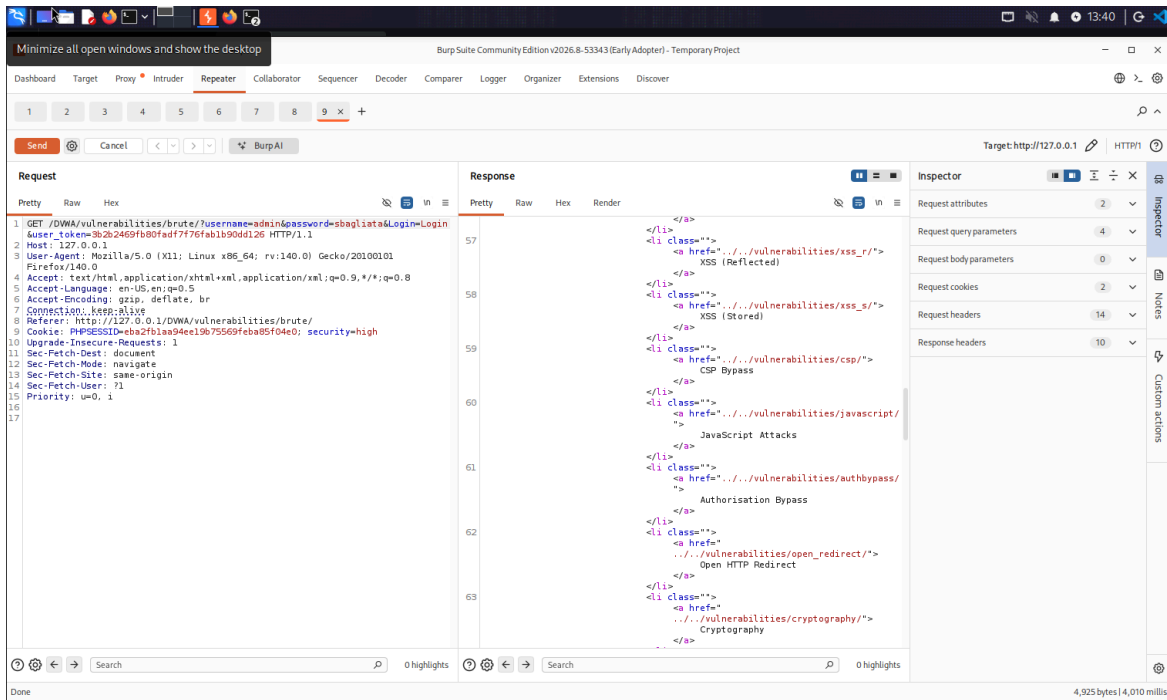
A livello **low**, la richiesta è stata una GET priva di token e la risposta «Username and/or password incorrect.» arrivata in circa **1.021 ms**.



A livello **medium**, la richiesta è stata identica ma la risposta ha impiegato circa **3.010 ms**: un ritardo dopo ogni tentativo fallito, per rallentare un attacco automatizzato.



A livello **high**, nella richiesta è comparso il parametro `user_token` (assente ai livelli precedenti) e il tempo di risposta è variato a ogni invio (qui sotto ad esempio 4.010 ms e poi 1.013 ms). Il token quindi è monouso e va riletto a ogni tentativo, rendendo molto più complessa l'automazione dell'attacco.



In sintesi, al crescere del livello la protezione contro il brute force aumenta per gradi:

- **Low** — nessuna protezione: nessun token, nessun ritardo; l'attacco è diretto.
- **Medium** — ritardo fisso dopo ogni tentativo fallito, che rallenta il brute force.
- **High** — token anti-CSRF monouso più ritardo casuale, che complicano fortemente l'automazione.